Tên học phần: **AN TOÀN THÔNG TIN**
Số tín chỉ: **3**
Giảng viên: **TS. Lê Quốc Tuấn**

ĐỀ TÀI ĐỒ ÁN MÔN HỌC
AN TOÀN THÔNG TIN

Dành cho nhóm 3 sinh viên

Bám sát sáu chương của Bài giảng An toàn thông tin
Định hướng nghiên cứu triển khai đo lường đánh giá

Thành phố Hồ Chí Minh 2026

Hướng dẫn sử dụng bộ đề tài

Bộ đề tài được thiết kế cho nhóm ba sinh viên và mở rộng trực tiếp từ nội dung sáu chương của bài giảng. Mỗi đề tài yêu cầu nhóm giải thích cơ sở lý thuyết, xây dựng hoặc mô phỏng một hệ thống, thực hiện phép thử có kiểm soát, đo kết quả và chỉ ra giới hạn của kết luận. Giảng viên có thể điều chỉnh thời lượng, công cụ và ngưỡng kết quả theo điều kiện phòng máy.

Nguyên tắc tổ chức

- Mỗi nhóm có ba thành viên. Cả ba phải tham gia thiết kế, thực nghiệm, phân tích và bảo vệ; không chia tách theo kiểu một người chỉ viết báo cáo.
- Tỷ trọng khuyến nghị gồm 20 đến 25 phần trăm cơ sở lý thuyết, 50 đến 60 phần trăm thiết kế và thực nghiệm, phần còn lại dành cho đánh giá kết quả, giới hạn và đề xuất cải tiến.
- Nhóm nộp đề cương sớm để giảng viên phê duyệt phạm vi, dữ liệu, môi trường, chỉ số, điều kiện an toàn và khối lượng phù hợp.
- Mọi phép thử bảo mật phải thực hiện trên máy ảo, container, sandbox hoặc dữ liệu mô phỏng do nhóm kiểm soát.
- Phiên bản công cụ phải được ghi trong báo cáo. Nhóm ưu tiên tài liệu chính thức và kiểm tra lại khả năng tái tạo trên máy khác.

Tiến độ gợi ý

Giai đoạn	Thời điểm	Nội dung	Minh chứng
Đề cương	Tuần 1	Câu hỏi nghiên cứu, phạm vi, kiến trúc, dữ liệu, chỉ số và phân công	Phiếu phê duyệt đề cương
Thiết kế	Tuần 2	Mô hình đe dọa, kế hoạch thử nghiệm và tiêu chí chấp nhận	Sơ đồ, test plan, baseline
Triển khai	Tuần 3 đến 4	Nguyên mẫu, cấu hình, thu log và sửa lỗi	Mã nguồn, cấu hình, nhật ký
Đánh giá	Tuần 5	Chạy lặp, tổng hợp số liệu, phân tích giới hạn	CSV, biểu đồ, bảng kết quả
Bàn giao	Tuần 6	Báo cáo, demo, bảo vệ và hướng dẫn tái tạo	Hồ sơ nộp hoàn chỉnh

Hồ sơ nộp chung

- Báo cáo Word hoặc PDF khoảng 25 đến 35 trang, không tính phụ lục mã và log; cấu trúc gồm vấn đề, lý thuyết, thiết kế, thực nghiệm, kết quả, thảo luận, giới hạn, kết luận và tài liệu tham khảo IEEE.
- Kho mã nguồn hoặc gói cấu hình có README, phiên bản công cụ, lệnh cài đặt, lệnh chạy, dữ liệu mẫu, seed nếu có và quy trình hoàn nguyên.
- Bảng truy vết minh chứng gồm mã minh chứng, phép thử, kết quả mong đợi, kết quả thực tế, tệp hoặc ảnh liên quan và thành viên chịu trách nhiệm.
- Tệp dữ liệu kết quả ở định dạng có thể xử lý lại như CSV hoặc JSON; ảnh chụp chỉ dùng để chứng minh trạng thái giao diện, không thay thế dữ liệu đo.
- Bản trình bày và video demo ngắn nếu giảng viên yêu cầu; cả ba thành viên phải trả lời câu hỏi về phần mình thực hiện và kiến trúc chung.

- Bảng công khai việc sử dụng AI, nêu công cụ, mục đích, nội dung đã kiểm tra và phần do nhóm tự chịu trách nhiệm.

Khung chấm điểm gợi ý (Thuyết trình)

Tiêu chí	Điểm	Căn cứ chấm
Xác định vấn đề và phạm vi	10	Câu hỏi nghiên cứu rõ, phạm vi hợp pháp, giả định và tiêu chí chấp nhận phù hợp
Cơ sở lý thuyết	15	Giải thích đúng cơ chế, dùng nguồn đáng tin cậy, liên hệ trực tiếp với thiết kế
Thiết kế và phương pháp	15	Kiến trúc, mô hình đe dọa, kế hoạch thử nghiệm và chỉ số có căn cứ
Triển khai kỹ thuật	25	Nguyên mẫu hoạt động, cấu hình đúng, mã rõ và xử lý lỗi hợp lý
Thực nghiệm và minh chứng	20	Có baseline, ca kiểm thử dương âm, dữ liệu đo, log và khả năng tái tạo
Phân tích và giới hạn	10	Diễn giải đúng số liệu, không kết luận quá mức, chỉ ra hạn chế và hướng cải tiến
Báo cáo, bảo vệ và đóng góp	5	Hồ sơ rõ ràng, trích dẫn IEEE, cả ba thành viên hiểu hệ thống và có đóng góp xác minh được

Danh mục 30 đề tài

Mã	Đề tài	Chương	Mức độ
01	Kiểm kê và phân loại tài sản thông tin cho trường đại học số	1	Trung bình
02	Mô hình hóa giá trị thông tin và tác động của sự cố đối với dịch vụ số	1	Trung bình
03	Bản đồ luồng thông tin và ranh giới tin cậy trong môi trường làm việc lai	1	Khá
04	Thiết kế đường cơ sở an toàn cho danh tính số cá nhân và học tập	1	Trung bình
05	Khung bảo vệ dữ liệu cho trợ lý trí tuệ nhân tạo dùng trong nhà trường	1	Khá
06	Đánh giá rủi ro an toàn thông tin cho doanh nghiệp vừa và nhỏ	2	Trung bình
07	Quét lỗ hổng và ưu tiên khắc phục dựa trên ngữ cảnh tài sản	2	Khá
08	Đánh giá khả năng phục hồi trước sự cố mã hóa tống tiền bằng mô phỏng an toàn	2	Khá
09	Đo hiệu quả nhận diện nội dung lừa đảo được tạo bởi trí tuệ nhân tạo	2	Trung bình
10	Tích hợp kiểm soát an toàn vào vòng đời phát triển ứng dụng Web	2	Khá
11	Sinh số nguyên tố và đánh giá thuật toán Miller Rabin	3	Khá
12	Từ thuật toán Euclid mở rộng đến mô phỏng hệ mật RSA	3	Khá
13	Trao đổi khóa Diffie Hellman và vai trò của xác thực	3	Khá
14	Phép toán đường cong elliptic và so sánh ECDH với DH hữu hạn	3	Nâng cao
15	Đánh giá nguồn ngẫu nhiên và ảnh hưởng đến khóa cùng nonce	3	Khá
16	So sánh AES GCM và ChaCha20 Poly1305 trong mã hóa có xác thực	4	Khá
17	Thiết kế hệ mã lai cho trao đổi tệp có xác thực	4	Nâng cao

18	Phân biệt hàm băm HMAC và AEAD qua thực nghiệm sửa đổi dữ liệu	4	Trung bình
19	Đánh giá chữ ký số cho phần mềm và tài liệu điện tử	4	Khá
20	Xây dựng hạ tầng khóa công khai thu nhỏ và kiểm thử TLS 1.3	4	Nâng cao
21	Đánh giá phòng vệ trước prompt injection trong hệ thống RAG	5	Nâng cao
22	Tấn công suy luận thành viên và quyền riêng tư vi sai trên mô hình học máy	5	Nâng cao
23	Phát hiện đầu độc dữ liệu và kiểm soát nguồn gốc tập huấn luyện	5	Nâng cao
24	Học liên kết kết hợp quyền riêng tư vi sai trong dữ liệu không đồng nhất	5	Nâng cao
25	Kiểm kê mật mã và thử nghiệm lộ trình chuyển đổi hậu lượng tử	5	Nâng cao
26	Mô hình hóa mối đe dọa STRIDE cho ngân hàng số trên đám mây	6	Khá
27	Kiểm thử phân quyền đối tượng và giới hạn lạm dụng API	6	Khá
28	Kiến trúc Zero Trust cho ứng dụng vi dịch vụ trong Kubernetes	6	Nâng cao
29	Quản lý bí mật và khóa cho vi dịch vụ bằng thông tin xác thực ngắn hạn	6	Nâng cao
30	Kiến trúc an toàn cho tác tử AI tạo yêu cầu thanh toán và sổ kiểm toán chống sửa đổi	6	Nâng cao

Chương 1 Tổng quan về An toàn thông tin

Năm đề tài trong phần này chuyển kiến thức của chương thành nhiệm vụ nghiên cứu có sản phẩm và số liệu kiểm chứng. Nhóm cần chọn phạm vi vừa đủ, lập baseline, giữ nguyên điều kiện so sánh và báo cáo cả kết quả không đạt kỳ vọng.

01 Kiểm kê và phân loại tài sản thông tin cho trường đại học số

Bám sát mục	1.1, 1.2, 1.4, 1.5 và 1.6	**Mức độ**	Trung bình
Thời lượng	6 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Xây dựng phương pháp nhận diện tài sản thông tin, chủ sở hữu, nơi lưu trữ, thời hạn sử dụng và mức độ quan trọng đối với hoạt động đào tạo.
- Áp dụng bộ ba bí mật, toàn vẹn, sẵn sàng và các thuộc tính mở rộng để hình thành quy tắc phân loại có thể kiểm tra.
- Đề xuất tập kiểm soát phù hợp với từng lớp dữ liệu thay vì áp dụng một mức bảo vệ cho mọi tài sản.

Nội dung lý thuyết cần báo cáo

- Giá trị chiến lược của thông tin và mối quan hệ giữa tài sản, quy trình nghiệp vụ, chủ sở hữu và người sử dụng.
- Các mô hình phân loại dữ liệu; bộ ba bí mật, toàn vẹn, sẵn sàng; tính xác thực, quyền kiểm soát và tính hữu dụng.
- Vòng đời dữ liệu từ tạo lập, truyền, lưu trữ, khai thác, lưu trữ lâu dài đến hủy bỏ.
- Nguyên tắc quyền tối thiểu, cần biết, phân tách trách nhiệm và phòng thủ theo chiều sâu.

Yêu cầu thực nghiệm

1. Tạo bộ dữ liệu mô phỏng từ 80 đến 120 tài sản gồm hồ sơ sinh viên, điểm, học phí, tài khoản, học liệu, log và cấu hình hệ thống.
2. Thiết kế bộ tiêu chí và chấm điểm tài sản theo tác động nếu mất bí mật, toàn vẹn hoặc sẵn sàng.
3. Xây dựng quy tắc phân loại tự động bằng bảng tính hoặc chương trình Python; so sánh với kết quả phân loại thủ công của nhóm.
4. Chọn ít nhất 10 luồng dữ liệu quan trọng, xác định điểm chuyển giao trách nhiệm và kiểm soát cần áp dụng.
5. Thực hiện kiểm thử tình huống đổi nhãn dữ liệu, cấp quyền sai và lưu trữ quá thời hạn để đánh giá tính nhất quán của quy tắc.

Kết quả thực nghiệm cần đạt

- Danh mục tài sản có chủ sở hữu, vị trí, lớp dữ liệu, mức tác động và thời hạn lưu giữ.
- Ma trận phân loại và bản đồ tối thiểu 10 luồng dữ liệu kèm điểm kiểm soát.
- Báo cáo độ nhất quán giữa phân loại tự động và thủ công, nêu rõ các trường hợp sai lệch và cách hiệu chỉnh.
- Bộ chính sách xử lý cho từng lớp dữ liệu, bao gồm truy cập, mã hóa, sao lưu, chia sẻ và hủy dữ liệu.

Sản phẩm và minh chứng bắt buộc

- Tệp dữ liệu mô phỏng và từ điển dữ liệu
- Bảng điểm tài sản và lịch sử hiệu chỉnh quy tắc
- Sơ đồ luồng dữ liệu có ranh giới tin cậy
- Ảnh chụp hoặc log của các phép thử sai nhãn và sai quyền
- Bảng phân công ba thành viên và nhật ký đóng góp

Công nghệ gợi ý Excel hoặc LibreOffice Calc, Python và pandas, diagrams.net hoặc OWASP Threat Dragon; có thể dùng Microsoft Purview Information Protection ở mức minh họa nếu có giấy phép.

Giới hạn an toàn và đạo đức Chỉ dùng dữ liệu giả lập; không thu thập hồ sơ thật của sinh viên, giảng viên hoặc nhân viên.

02 Mô hình hóa giá trị thông tin và tác động của sự cố đối với dịch vụ số

Bám sát mục	1.1, 1.2, 1.3 và 1.5	**Mức độ**	Trung bình
Thời lượng	6 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Lượng hóa tương đối giá trị của thông tin dựa trên mức phụ thuộc của quy trình nghiệp vụ.
- Phân tích tác động trực tiếp và gián tiếp của các sự cố bí mật, toàn vẹn và sẵn sàng.
- Kiểm tra độ nhạy của quyết định đầu tư bảo vệ khi giả định xác suất và chi phí thay đổi.

Nội dung lý thuyết cần báo cáo

- Giá trị sử dụng, giá trị thay thế và giá trị pháp lý của thông tin.
- Tác động của sự cố đến vận hành, tài chính, uy tín, nghĩa vụ pháp lý và an toàn con người.
- Khái niệm xác suất, mức phơi bày, tổn thất kỳ vọng và giới hạn của định lượng rủi ro.
- Phân biệt số liệu quan sát, giả định chuyên gia và kết quả mô phỏng.

Yêu cầu thực nghiệm

1. Chọn một dịch vụ giả lập như đăng ký học phần, thương mại điện tử hoặc khám bệnh trực tuyến.
2. Xây dựng ít nhất 12 kịch bản sự cố và mô tả tài sản, tác nhân, điều kiện, thuộc tính bị ảnh hưởng và thời gian gián đoạn.
3. Lập mô hình chi phí bằng bảng tính hoặc Python với ba mức giả định lạc quan, cơ sở và bất lợi.
4. Thực hiện phân tích độ nhạy cho xác suất, thời gian ngừng dịch vụ và chi phí phục hồi.
5. So sánh tối thiểu ba phương án kiểm soát theo mức giảm rủi ro và chi phí triển khai.

Kết quả thực nghiệm cần đạt

- Mô hình có thể thay đổi tham số và tái tạo kết quả.
- Bảng xếp hạng kịch bản theo tổn thất kỳ vọng và mức bất định.
- Biểu đồ độ nhạy chỉ ra tham số ảnh hưởng mạnh đến quyết định.

- Khuyến nghị đầu tư có nêu giả định, giới hạn và tiêu chí chấp nhận rủi ro.

Sản phẩm và minh chứng bắt buộc

- Tệp mô hình có công thức hoặc mã nguồn
- Bộ giả định và nguồn hình thành giả định
- Bảng kết quả của ba kịch bản
- Biểu đồ độ nhạy và biên bản kiểm thử công thức
- Video ngắn tái chạy mô hình với bộ tham số mới

Công nghệ gợi ý Excel hoặc LibreOffice Calc; Python với pandas, NumPy và matplotlib; Power BI chỉ dùng nếu nhóm đã quen.

Giới hạn an toàn và đạo đức Không dùng số liệu tổn thất bí mật của tổ chức thật nếu chưa được cho phép; các con số mô phỏng phải được ghi rõ là giả định.

03 Bản đồ luồng thông tin và ranh giới tin cậy trong môi trường làm việc lai

Bám sát mục	1.3, 1.4, 1.5 và 1.6	**Mức độ**	Khá
Thời lượng	6 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Mô tả cách thông tin đi qua thiết bị cá nhân, mạng Internet, dịch vụ đám mây và hệ thống nội bộ.
- Nhận diện ranh giới nơi giả định tin cậy thay đổi và xác định kiểm soát cần đặt tại đúng vị trí.
- Đánh giá sự khác biệt giữa bảo vệ nội dung và bảo vệ siêu dữ liệu truyền thông.

Nội dung lý thuyết cần báo cáo

- Mô hình hệ thống, luồng dữ liệu, vùng tin cậy và bề mặt tấn công.
- Bảo mật dữ liệu khi truyền, khi lưu trữ và khi xử lý.
- Vai trò của xác thực, mã hóa kênh, phân đoạn mạng, ghi log và kiểm soát thiết bị đầu cuối.
- Giới hạn của mã hóa đối với siêu dữ liệu như địa chỉ, thời gian và kích thước lưu lượng.

Yêu cầu thực nghiệm

1. Dựng phòng thí nghiệm gồm máy người dùng, máy chủ ứng dụng, dịch vụ tệp và một cổng truy cập từ xa trong mạng ảo.
2. Vẽ sơ đồ luồng dữ liệu trước khi cấu hình, đánh dấu tài sản và ranh giới tin cậy.
3. Thu lưu lượng của các giao thức được phép trong lab ở trạng thái không bảo vệ và có TLS hoặc SSH.
4. So sánh nội dung quan sát được, siêu dữ liệu còn lộ và sự kiện ghi nhận tại từng điểm.
5. Áp dụng ít nhất ba kiểm soát rồi thực hiện lại cùng bộ kiểm thử để đánh giá thay đổi.

Kết quả thực nghiệm cần đạt

- Sơ đồ kiến trúc và luồng dữ liệu khớp với lưu lượng thực tế.
- Bảng so sánh dữ liệu nhìn thấy trước và sau khi bảo vệ kênh.

- Danh sách ranh giới tin cậy, giả định và kiểm soát còn thiếu.
- Khuyến nghị cho làm việc từ xa dựa trên bằng chứng thu được trong lab.

Sản phẩm và minh chứng bắt buộc

- Tệp cấu hình mạng ảo hoặc Docker Compose
- Sơ đồ luồng dữ liệu có đánh số
- Tệp pcap đã khử thông tin nhạy cảm
- Bảng truy vết từng phép thử đến ảnh chụp hoặc log
- Hướng dẫn tái tạo phòng thí nghiệm

Công nghệ gợi ý VirtualBox hoặc VMware, Docker, Wireshark, OpenSSH, Nginx hoặc Caddy, diagrams.net.

Giới hạn an toàn và đạo đức Chỉ thu lưu lượng do nhóm tạo trong mạng cô lập; không nghe lén mạng dùng chung hoặc tài khoản thật.

04 Thiết kế đường cơ sở an toàn cho danh tính số cá nhân và học tập

Bám sát mục	1.2, 1.5, 1.6 và 1.8	**Mức độ**	Trung bình
Thời lượng	6 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Chuyển các mục tiêu an toàn thông tin thành yêu cầu cấu hình có thể kiểm tra đối với tài khoản và thiết bị.
- Đánh giá tác dụng riêng và tác dụng kết hợp của mật khẩu, xác thực đa yếu tố, sao lưu và giám sát.
- Xây dựng hướng dẫn có thể áp dụng cho người học mà không phụ thuộc một nhà cung cấp duy nhất.

Nội dung lý thuyết cần báo cáo

- Xác thực, phân quyền, quản lý phiên và phục hồi tài khoản.
- Nguyên tắc mặc định an toàn, quyền tối thiểu và phòng thủ theo chiều sâu.
- Mối quan hệ giữa khả năng sử dụng, khả năng phục hồi và mức bảo vệ.
- Các rủi ro từ tái sử dụng mật khẩu, đánh cắp phiên, thiết bị thất lạc và đồng bộ dữ liệu.

Yêu cầu thực nghiệm

1. Dựng hệ thống danh tính thử nghiệm bằng Keycloak hoặc nền tảng tương đương với ít nhất ba vai trò.
2. Thiết lập hai đường cơ sở: cấu hình tối thiểu và cấu hình tăng cường.
3. Tạo bộ 15 tình huống kiểm thử gồm mật khẩu yếu, đăng nhập bất thường, phiên hết hạn, mất thiết bị và khôi phục tài khoản.
4. Đo tỷ lệ tình huống bị ngăn chặn, thời gian phục hồi và số bước người dùng phải thực hiện.
5. Tổ chức đánh giá khả năng sử dụng trong nội bộ nhóm bằng kịch bản định sẵn, không thu thập dữ liệu nhạy cảm.

Kết quả thực nghiệm cần đạt

- Danh mục kiểm soát và cách kiểm tra từng kiểm soát.
- Bảng kết quả trước và sau khi tăng cường cấu hình.
- Quy trình phục hồi tài khoản có xác minh danh tính và lưu vết.
- Bộ hướng dẫn ngắn cho sinh viên kèm giải thích lý do của từng khuyến nghị.

Sản phẩm và minh chứng bắt buộc

- Bản xuất cấu hình đã loại bỏ bí mật
- Ma trận vai trò và quyền
- Nhật ký 15 phép thử
- Số liệu thời gian và số bước phục hồi
- Phiếu tự đánh giá đóng góp cá nhân

Công nghệ gợi ý Keycloak, Docker, ứng dụng thử nghiệm đơn giản, TOTP authenticator, OpenTelemetry hoặc log mặc định của nền tảng.

Giới hạn an toàn và đạo đức Không yêu cầu thành viên cung cấp mật khẩu thật; toàn bộ tài khoản và mã TOTP phải dành riêng cho phòng thí nghiệm.

05 Khung bảo vệ dữ liệu cho trợ lý trí tuệ nhân tạo dùng trong nhà trường

Bám sát mục	1.4, 1.5, 1.6 và 1.8	**Mức độ**	Khá
Thời lượng	7 đến 8 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Nhận diện dữ liệu, mô hình, chỉ dẫn hệ thống, nhật ký và công cụ là các tài sản khác nhau cần bảo vệ.
- Thiết kế yêu cầu dữ liệu tối thiểu, phân quyền, giám sát và xử lý sự cố cho một trợ lý AI nội bộ.
- Kiểm chứng một số kiểm soát bằng nguyên mẫu dùng tài liệu giả lập.

Nội dung lý thuyết cần báo cáo

- Tài sản và thuộc tính an toàn của hệ thống AI; quyền riêng tư, tính minh bạch và khả năng kiểm toán.
- Luồng dữ liệu của chatbot truy xuất tăng cường, gồm nạp tài liệu, lập chỉ mục, truy xuất, suy luận và ghi log.
- Rủi ro rò rỉ dữ liệu, chỉ dẫn độc hại, quyền công cụ quá rộng và lưu giữ nhật ký quá mức.
- Quản trị rủi ro AI theo vòng đời và trách nhiệm của con người trong phê duyệt hành động nhạy cảm.

Yêu cầu thực nghiệm

1. Dựng trợ lý cục bộ trên bộ tài liệu giả lập có ba mức phân loại và ba nhóm người dùng.
2. Thiết lập kiểm tra quyền trước truy xuất, lọc thông tin nhạy cảm và chính sách thời hạn lưu log.
3. Xây dựng tối thiểu 25 truy vấn bình thường và 15 truy vấn cố gắng vượt quyền hoặc làm lộ dữ liệu.

4. So sánh tỷ lệ trả lời đúng, tỷ lệ từ chối đúng, tỷ lệ rò rỉ và độ trễ trước và sau khi áp dụng kiểm soát.
5. Phân tích các trường hợp kiểm soát gây từ chối nhầm hoặc vẫn để lọt thông tin.

Kết quả thực nghiệm cần đạt

- Mô hình tài sản và luồng dữ liệu của trợ lý AI.
- Nguyên mẫu chứng minh kiểm soát quyền truy xuất và lọc đầu ra.
- Bộ kiểm thử có nhãn cùng bảng kết quả tái tạo được.
- Chính sách sử dụng, lưu log và xử lý yêu cầu xóa dữ liệu ở mức đề xuất.

Sản phẩm và minh chứng bắt buộc

- Bộ tài liệu giả lập và nhãn phân loại
- Mã nguồn hoặc cấu hình nguyên mẫu
- Nhật ký kiểm thử đã ẩn dữ liệu nhạy cảm
- Bảng lỗi lọt và từ chối nhầm
- Sơ đồ trách nhiệm giữa người dùng, quản trị viên và đơn vị dữ liệu

Công nghệ gợi ý Ollama hoặc mô hình nhỏ chạy cục bộ, LangChain hoặc LlamaIndex, Chroma hoặc FAISS, Python, Docker; có thể thay bằng nguyên mẫu quy tắc nếu máy không đủ tài nguyên.

Giới hạn an toàn và đạo đức Chỉ dùng dữ liệu giả lập hoặc dữ liệu công khai được phép; không đưa dữ liệu nội bộ lên dịch vụ AI công cộng.

Chương 2 Nền tảng tư duy và quản trị rủi ro An toàn thông tin

Năm đề tài trong phần này chuyển kiến thức của chương thành nhiệm vụ nghiên cứu có sản phẩm và số liệu kiểm chứng. Nhóm cần chọn phạm vi vừa đủ, lập baseline, giữ nguyên điều kiện so sánh và báo cáo cả kết quả không đạt kỳ vọng.

06 Đánh giá rủi ro an toàn thông tin cho doanh nghiệp vừa và nhỏ

Bám sát mục	2.1 đến 2.5	**Mức độ**	Trung bình
Thời lượng	6 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Thực hiện đầy đủ quy trình xác định bối cảnh, tài sản, đe dọa, lỗ hổng, tác động và phương án xử lý.
- So sánh kết quả định tính với một mô hình bán định lượng để nhận diện độ nhạy của thứ tự ưu tiên.
- Xây dựng sổ đăng ký rủi ro có chủ sở hữu và bằng chứng kiểm soát.

Nội dung lý thuyết cần báo cáo

- Khái niệm rủi ro, mối đe dọa, lỗ hổng, tác động, khả năng xảy ra và rủi ro còn lại.
- Bốn chiến lược xử lý gồm tránh, giảm, chuyển giao và chấp nhận.
- Hướng dẫn NIST SP 800-30, ISO/IEC 27005 và mối liên hệ với NIST CSF 2.0.
- Giới hạn của ma trận rủi ro, thiên lệch đánh giá và yêu cầu ghi rõ giả định.

Yêu cầu thực nghiệm

1. Xây dựng hồ sơ doanh nghiệp giả lập gồm mạng, ứng dụng, người dùng, nhà cung cấp và dữ liệu.
2. Nhận diện ít nhất 20 kịch bản rủi ro, trong đó có con người, phần mềm, chuỗi cung ứng và gián đoạn dịch vụ.
3. Chấm điểm bằng hai phương pháp; thực hiện phiên hiệu chỉnh nội bộ để giảm khác biệt giữa ba thành viên.
4. Chọn năm rủi ro cao nhất, đề xuất kiểm soát và ước lượng rủi ro còn lại.
5. Thay đổi ba giả định quan trọng để kiểm tra thứ tự ưu tiên có ổn định hay không.

Kết quả thực nghiệm cần đạt

- Sổ đăng ký rủi ro có truy vết từ tài sản đến kiểm soát.
- So sánh hai phương pháp chấm điểm và giải thích chênh lệch.
- Kế hoạch xử lý có thời hạn, chủ sở hữu, chi phí tương đối và chỉ số theo dõi.
- Báo cáo độ nhạy và các quyết định cần giảng viên hoặc lãnh đạo phê duyệt.

Sản phẩm và minh chứng bắt buộc

- Hồ sơ tổ chức giả lập
- Biên bản nhận diện và hiệu chỉnh rủi ro
- Tệp tính điểm có công thức
- Sổ đăng ký rủi ro và kế hoạch xử lý
- Bảng truy vết nguồn bằng chứng

Công nghệ gợi ý Excel hoặc LibreOffice Calc, Python tùy chọn, diagrams.net; có thể dùng công cụ quản trị rủi ro mã nguồn mở nếu nhóm tự triển khai được.

Giới hạn an toàn và đạo đức Không công bố sơ đồ hoặc lỗ hổng của doanh nghiệp thật; nếu khảo sát tổ chức thật phải có văn bản cho phép và ẩn danh dữ liệu.

07 Quét lỗ hổng và ưu tiên khắc phục dựa trên ngữ cảnh tài sản

Bám sát mục	2.5.3, 2.5.4, 2.8 và 2.9	**Mức độ**	Khá
Thời lượng	7 đến 8 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Phân biệt phát hiện kỹ thuật với quyết định ưu tiên rủi ro.
- Kết hợp CVSS với mức quan trọng tài sản, khả năng khai thác trong lab và kiểm soát hiện có.
- Đánh giá sai dương, sai âm và chất lượng bằng chứng của công cụ quét.

Nội dung lý thuyết cần báo cáo

- CVE, CWE, CAPEC, CVSS và chuỗi từ điểm yếu đến tác động.
- Quét có thông tin xác thực và không xác thực; giới hạn của dấu hiệu phiên bản.
- Ưu tiên dựa trên bối cảnh, khả năng tiếp cận, mức phơi bày và giá trị tài sản.
- Quản lý bản vá, kiểm thử hồi quy, ngoại lệ và biện pháp bù.

Yêu cầu thực nghiệm

1. Dựng mạng cô lập có hai hoặc ba máy ảo dễ tổn thương được thiết kế cho đào tạo.
2. Lập danh mục dịch vụ trước khi quét và dự đoán các phát hiện có thể xuất hiện.
3. Sử dụng ít nhất hai công cụ để quét cùng phạm vi; đối chiếu phát hiện bằng kiểm tra cấu hình hoặc phiên bản.
4. Xây dựng công thức ưu tiên kết hợp CVSS và ngữ cảnh tài sản; so sánh với thứ tự chỉ dựa trên CVSS.
5. Khắc phục một tập nhỏ vấn đề an toàn, quét lại và ghi nhận lỗi chức năng nếu có.

Kết quả thực nghiệm cần đạt

- Bảng phát hiện hợp nhất, loại bỏ trùng lặp và đánh dấu độ tin cậy.
- Danh sách ưu tiên trước và sau khi đưa ngữ cảnh tài sản vào mô hình.
- Bằng chứng quét lại chứng minh trạng thái đã khắc phục hoặc lý do chấp nhận ngoại lệ.
- Hướng dẫn diễn giải báo cáo quét cho người quản trị không chuyên bảo mật.

Sản phẩm và minh chứng bắt buộc

- Sơ đồ mạng lab và phạm vi được phép
- Báo cáo gốc của hai công cụ
- Nhật ký xác minh thủ công
- Tệp tính ưu tiên và bảng before after
- Kế hoạch hoàn nguyên khi bản vá gây lỗi

Công nghệ gợi ý Nmap, Greenbone Community Edition hoặc Nessus Essentials nếu được phép, OpenVAS, Docker, máy ảo Metasploitable hoặc ứng dụng đào tạo tương đương.

Giới hạn an toàn và đạo đức Chỉ quét địa chỉ thuộc mạng lab do nhóm sở hữu; cấm quét Internet, hệ thống trường hoặc địa chỉ bên thứ ba.

08 Đánh giá khả năng phục hồi trước sự cố mã hóa tống tiền bằng mô phỏng an toàn

Bám sát mục	2.2.3, 2.5, 2.9.2 và 2.9.3	**Mức độ**	Khá
Thời lượng	6 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Đánh giá khả năng phòng ngừa, phát hiện, cô lập và phục hồi thay vì tập trung vào mã độc.
- Đo mục tiêu điểm khôi phục, thời gian khôi phục và tỷ lệ dữ liệu phục hồi đúng.
- Thiết kế quy trình phối hợp kỹ thuật và nghiệp vụ khi dịch vụ bị gián đoạn.

Nội dung lý thuyết cần báo cáo

- Chuỗi sự kiện của mã độc tống tiền dưới dạng dịch vụ và các điểm có thể phát hiện.
- Sao lưu 3-2-1, bản sao cách ly hoặc bất biến, quyền tối thiểu và phân đoạn.
- RPO, RTO, tính toàn vẹn bản sao lưu và kiểm thử phục hồi.
- Quy trình ứng phó sự cố, bảo quản bằng chứng và truyền thông nội bộ.

Yêu cầu thực nghiệm

1. Dựng máy chủ tệp với dữ liệu giả và hệ thống sao lưu trong mạng ảo.
2. Viết trình mô phỏng lành tính chỉ đổi tên hoặc mã hóa thư mục mẫu bằng khóa được giữ an toàn; không có cơ chế tự lây lan hay né tránh.
3. Chạy các kịch bản mất máy chủ, mất tài khoản quản trị, bản sao lưu trực tuyến bị sửa và bản sao cách ly còn nguyên.
4. Đo thời gian phát hiện, cô lập, phục hồi và kiểm tra hàm băm của tệp sau phục hồi.
5. Tổ chức diễn tập bàn giấy để phân công quyết định, kênh liên lạc và điều kiện đưa dịch vụ trở lại.

Kết quả thực nghiệm cần đạt

- Kiến trúc sao lưu và phục hồi có ranh giới quyền rõ ràng.
- Bảng đo RPO, RTO và tỷ lệ tệp phục hồi cho từng kịch bản.
- Runbook ứng phó gồm phát hiện, cô lập, bảo toàn bằng chứng, phục hồi và xác nhận nghiệp vụ.
- Danh sách điểm thất bại và cải tiến sau diễn tập.

Sản phẩm và minh chứng bắt buộc

- Cấu hình sao lưu đã che bí mật
- Bộ dữ liệu mẫu và giá trị băm trước sự cố
- Log mô phỏng và phục hồi
- Biên bản diễn tập bàn giấy
- Video phục hồi một tình huống đã chọn

Công nghệ gợi ý VirtualBox hoặc VMware, Restic hoặc BorgBackup, MinIO có versioning tùy chọn, Wazuh hoặc Sysmon và công cụ băm.

Giới hạn an toàn và đạo đức Trình mô phỏng chỉ được xử lý thư mục mẫu, phải có đường dẫn cố định và kiểm tra chặn chạy ngoài lab; không phát triển hoặc sử dụng mã độc thật.

09 Đo hiệu quả nhận diện nội dung lừa đảo được tạo bởi trí tuệ nhân tạo

Bám sát mục	2.6, 2.7 và 2.9.3	**Mức độ**	Trung bình
Thời lượng	6 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Phân tích cách nội dung tổng hợp làm thay đổi dấu hiệu nhận biết lừa đảo.
- Thiết kế thử nghiệm trước và sau hướng dẫn để đo thay đổi hành vi nhận diện.
- Đề xuất kiểm soát kết hợp giữa con người, quy trình và kỹ thuật.

Nội dung lý thuyết cần báo cáo

- Kỹ nghệ xã hội, thiên lệch nhận thức, dấu hiệu tạo áp lực và giả mạo thẩm quyền.
- Nội dung tổng hợp giả mạo, cá nhân hóa và giới hạn của nhận diện bằng cảm quan.
- Thiết kế thực nghiệm có đồng thuận, ẩn danh và tránh gây hại cho người tham gia.
- Các chỉ số chính xác, precision, recall, thời gian quyết định và độ tự tin.

Yêu cầu thực nghiệm

1. Tạo bộ 60 thông điệp giả lập cân bằng giữa hợp lệ và lừa đảo, có cả mẫu viết thủ công và mẫu hỗ trợ bởi AI.
2. Xây dựng đáp án dựa trên chỉ dấu kỹ thuật và ngữ cảnh, không dựa riêng vào văn phong.
3. Tổ chức đánh giá nội bộ hoặc với người tham gia tự nguyện theo quy trình đã được giảng viên chấp thuận.
4. Cung cấp hướng dẫn ngắn rồi đo lại trên bộ câu hỏi khác có độ khó tương đương.
5. Phân tích loại thông điệp gây nhầm lẫn, mức cải thiện và dấu hiệu người học sử dụng.

Kết quả thực nghiệm cần đạt

- Bộ dữ liệu gắn nhãn và tiêu chí gắn nhãn.
- Báo cáo trước và sau hướng dẫn với khoảng tin cậy hoặc mô tả giới hạn mẫu.
- Danh sách kiểm tra nhận diện dựa trên ngữ cảnh, liên kết, danh tính và quy trình xác minh.
- Đề xuất cơ chế báo cáo và xác minh ngoài băng cho tổ chức.

Sản phẩm và minh chứng bắt buộc

- Phiếu đồng thuận và kế hoạch ẩn danh nếu có người tham gia
- Bộ câu hỏi hai phiên bản
- Mã phân tích hoặc bảng tính
- Biểu đồ lỗi theo nhóm dấu hiệu
- Tuyên bố cách sử dụng AI để tạo dữ liệu

Công nghệ gợi ý Python hoặc R, biểu mẫu khảo sát cục bộ, Jupyter, công cụ phân tích thống kê; AI chỉ dùng tạo dữ liệu giả và phải được rà soát thủ công.

Giới hạn an toàn và đạo đức Không gửi thư giả mạo tới địa chỉ thật, không thu mật khẩu hoặc dữ liệu định danh, không công khai mẫu có thể nhắm vào cá nhân cụ thể.

10 Tích hợp kiểm soát an toàn vào vòng đời phát triển ứng dụng Web

Bám sát mục	2.8, 2.9.1 và 2.9.4	**Mức độ**	Khá
Thời lượng	6 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Thiết kế đường ống kiểm tra an toàn từ mã nguồn đến bản dựng và môi trường thử nghiệm.
- Phân loại phát hiện từ SAST, SCA, DAST và quét bí mật theo rủi ro thực tế.
- Đo tác động của kiểm soát lên chất lượng bản dựng, thời gian xử lý và khả năng tái phát.

Nội dung lý thuyết cần báo cáo

- Secure SDLC, shift left, cổng chất lượng và phân tách trách nhiệm.
- OWASP Top 10, quản lý phụ thuộc, bí mật trong mã nguồn và cấu hình an toàn.
- Khác biệt giữa SAST, DAST, SCA và kiểm thử thủ công.
- SBOM, xuất xứ phần mềm, ngoại lệ có thời hạn và tiêu chí chặn phát hành.

Yêu cầu thực nghiệm

1. Chọn ứng dụng đào tạo hoặc ứng dụng nhỏ do nhóm tự viết và đóng gói bằng container.
2. Thiết lập pipeline gồm kiểm thử đơn vị, SAST, SCA, quét bí mật, tạo SBOM và DAST trên môi trường riêng.
3. Ghi nhận baseline rồi sửa tối thiểu năm vấn đề thuộc ít nhất ba nhóm khác nhau.
4. Tạo một thay đổi hồi quy có kiểm soát để kiểm tra cổng chất lượng có phát hiện hay không.
5. Đo thời gian pipeline, số phát hiện, tỷ lệ xác minh đúng và thời gian khắc phục.

Kết quả thực nghiệm cần đạt

- Pipeline chạy lặp lại được và dừng bản dựng theo chính sách đã định.
- Bảng truy vết phát hiện đến mã sửa, kiểm thử và bằng chứng quét lại.
- SBOM cùng quy trình xử lý thư viện có lỗ hổng.
- Đánh giá hạn chế của từng công cụ và đề xuất cân bằng giữa tốc độ với độ bao phủ.

Sản phẩm và minh chứng bắt buộc

- Kho mã nguồn và lịch sử commit
- Tệp pipeline và cấu hình công cụ
- Báo cáo baseline và sau khắc phục
- SBOM và nhật ký cổng chất lượng
- Video chạy pipeline từ commit đến báo cáo

Công nghệ gợi ý GitLab CI hoặc GitHub Actions chạy cục bộ nếu phù hợp, Semgrep, Bandit hoặc SpotBugs, Trivy, Gitleaks, OWASP ZAP, CycloneDX, Docker.

Giới hạn an toàn và đạo đức DAST chỉ được chạy với ứng dụng lab; không đưa bí mật thật vào kho mã nguồn để kiểm thử công cụ.

Chương 3 Cơ sở toán học cho mật mã học

Năm đề tài trong phần này chuyển kiến thức của chương thành nhiệm vụ nghiên cứu có sản phẩm và số liệu kiểm chứng. Nhóm cần chọn phạm vi vừa đủ, lập baseline, giữ nguyên điều kiện so sánh và báo cáo cả kết quả không đạt kỳ vọng.

11 Sinh số nguyên tố và đánh giá thuật toán Miller Rabin

Bám sát mục	3.3, 3.4, 3.6 và 3.11	**Mức độ**	Khá
Thời lượng	6 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Giải thích vai trò của số nguyên tố và phép toán modulo trong sinh khóa.
- Cài đặt Miller Rabin phục vụ học tập và đánh giá xác suất sai theo số vòng kiểm tra.
- So sánh cài đặt minh họa với thư viện mật mã đã được kiểm thử.

Nội dung lý thuyết cần báo cáo

- Số nguyên tố, hợp số, nguyên tố cùng nhau và định lý Fermat nhỏ.
- Số giả nguyên tố, số Carmichael và lý do phép thử Fermat đơn giản chưa đủ.
- Cơ sở của Miller Rabin, số vòng kiểm tra và xác suất sai.

- Yêu cầu ngẫu nhiên, kích thước tham số và giới hạn của cài đặt tự viết.

Yêu cầu thực nghiệm

1. Cài đặt phép thử chia thử, Fermat và Miller Rabin bằng Python cho mục đích so sánh.
2. Tạo tập số gồm số nguyên tố, hợp số, số Carmichael và số ngẫu nhiên ở nhiều độ dài bit.
3. Đo thời gian, tỷ lệ phát hiện hợp số và ảnh hưởng của số vòng kiểm tra.
4. Sinh ứng viên nguyên tố bằng nguồn ngẫu nhiên mật mã rồi xác minh bằng thư viện chuẩn.
5. Phân tích ít nhất ba trường hợp mà phép thử đơn giản cho kết quả gây hiểu nhầm.

Kết quả thực nghiệm cần đạt

- Mã nguồn có kiểm thử đơn vị và chú thích toán học.
- Bảng số liệu theo độ dài bit, thuật toán và số vòng kiểm tra.
- Giải thích định lượng về đánh đổi giữa thời gian và độ tin cậy.
- Khuyến nghị rõ rằng mã minh họa không được dùng để sinh khóa sản xuất.

Sản phẩm và minh chứng bắt buộc

- Bộ số kiểm thử và kết quả mong đợi
- Mã nguồn cùng kiểm thử
- Log benchmark có thông tin phần cứng
- Biểu đồ thời gian và tỷ lệ phát hiện
- Đối chiếu với thư viện chuẩn

Công nghệ gợi ý Python, Jupyter, pytest, secrets, SymPy hoặc PyCryptodome chỉ để đối chiếu.

Giới hạn an toàn và đạo đức Không sử dụng số nguyên tố hoặc khóa do chương trình minh họa sinh ra cho dữ liệu thật hay dịch vụ công khai.

12 Từ thuật toán Euclid mở rộng đến mô phỏng hệ mật RSA

Bám sát mục	3.4 đến 3.6 và 3.11	**Mức độ**	Khá
Thời lượng	6 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Liên kết ước chung lớn nhất, nghịch đảo modulo và định lý Euler với quá trình sinh khóa RSA.
- Mô phỏng RSA với tham số nhỏ để kiểm chứng công thức và nhận diện điều kiện sai.
- So sánh RSA thô trong bài toán với RSA OAEP và RSA PSS của thư viện chuẩn.

Nội dung lý thuyết cần báo cáo

- Thuật toán Euclid, Euclid mở rộng, phi Euler và hàm Carmichael.
- Sinh khóa, mã hóa, giải mã và điều kiện chọn số mũ công khai.
- Khái niệm hàm cửa sập và giả định khó của phân tích số nguyên.
- Mục đích của OAEP và PSS; lý do không dùng RSA thô trong hệ thống thật.

Yêu cầu thực nghiệm

1. Cài đặt Euclid mở rộng và kiểm thử với tập cặp số bao gồm trường hợp không có nghịch đảo.
2. Xây dựng mô phỏng RSA tham số nhỏ, hiển thị từng bước và kiểm tra tính đúng của khóa.
3. Tạo các lỗi có kiểm soát như p bằng q, e không nguyên tố cùng nhau hoặc thông điệp ngoài miền.
4. Dùng thư viện chuẩn để mã hóa OAEP và ký PSS với các kích thước khóa được hỗ trợ.
5. Đo thời gian sinh khóa, mã hóa, giải mã, ký và xác minh; giải thích giới hạn của phép đo.

Kết quả thực nghiệm cần đạt

- Công cụ học tập thể hiện rõ các bước toán học và thông báo lỗi đúng.
- Bộ kiểm thử chứng minh điều kiện cần của RSA.
- Bảng phân biệt mã hóa và chữ ký, RSA thô và lược đồ có đệm.
- Báo cáo benchmark và khuyến nghị sử dụng thư viện chuẩn.

Sản phẩm và minh chứng bắt buộc

- Mã nguồn mô phỏng và bộ kiểm thử
- Bảng truy vết công thức đến giá trị trung gian
- Tệp kết quả RSA OAEP và RSA PSS
- Log benchmark
- Phần giải thích của từng thành viên về một bước toán học

Công nghệ gợi ý Python, Jupyter, cryptography hoặc PyCryptodome, pytest; OpenSSL dùng để kiểm tra chéo tùy chọn.

Giới hạn an toàn và đạo đức Tham số nhỏ chỉ dùng minh họa; không tự triển khai RSA để bảo vệ dữ liệu thật.

13 Trao đổi khóa Diffie Hellman và vai trò của xác thực

Bám sát mục	3.7, 3.9, 3.10 và 3.15	**Mức độ**	Khá
Thời lượng	7 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Minh họa bất đối xứng tính toán của lũy thừa modulo và bài toán logarit rời rạc.
- Chứng minh rằng bí mật chung không tự cung cấp xác thực danh tính.
- Đánh giá cách chữ ký hoặc khóa đã chia sẻ bảo vệ bản ghi trao đổi.

Nội dung lý thuyết cần báo cáo

- Nhóm cyclic, phần tử sinh, bậc phần tử và phép lũy thừa modulo.
- Bài toán logarit rời rạc và trao đổi khóa Diffie Hellman.
- Tấn công xen giữa, xác thực bản ghi và dẫn xuất khóa theo ngữ cảnh.
- An toàn chuyển tiếp và khác biệt giữa tham số minh họa với nhóm được chuẩn hóa.

Yêu cầu thực nghiệm

1. Cài đặt phiên bản tham số nhỏ và xác minh hai bên thu được cùng bí mật.

2. Đo chi phí vét cạn logarit rời rạc trên các nhóm nhỏ tăng dần để quan sát tốc độ tăng.
3. Xây dựng mô phỏng ba tiến trình Alice, Bob và Mallory trong mạng cục bộ.
4. Chạy kịch bản không xác thực, sau đó bổ sung chữ ký hoặc MAC cho bản ghi trao đổi.
5. Dẫn xuất khóa phiên bằng HKDF và kiểm tra việc thay đổi ngữ cảnh tạo khóa khác nhau.

Kết quả thực nghiệm cần đạt

- Minh họa trực quan các giá trị công khai, bí mật và bản ghi trao đổi.
- Bằng chứng tấn công xen giữa thành công khi thiếu xác thực và thất bại sau kiểm soát.
- Biểu đồ chi phí tính toán trên tham số nhỏ kèm cảnh báo không ngoại suy quá mức.
- Bản mô tả giao thức đã sửa và các giả định tin cậy còn lại.

Sản phẩm và minh chứng bắt buộc

- Mã nguồn ba tiến trình
- Log của hai kịch bản
- Tệp khóa phiên đã băm để đối chiếu
- Biểu đồ benchmark
- Sơ đồ tuần tự giao thức

Công nghệ gợi ý Python sockets hoặc Docker Compose, cryptography, Wireshark, Jupyter.

Giới hạn an toàn và đạo đức Mô phỏng xen giữa chỉ chạy trên tiến trình và mạng do nhóm tạo; không can thiệp kết nối của người khác.

14 Phép toán đường cong elliptic và so sánh ECDH với DH hữu hạn

Bám sát mục	3.7, 3.8, 3.12 và 3.15	**Mức độ**	Nâng cao
Thời lượng	7 đến 8 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Hiểu phép cộng điểm, nhân vô hướng và vai trò của trường hữu hạn.
- Cài đặt đường cong nhỏ cho học tập và kiểm tra các trường hợp biên.
- So sánh kích thước khóa, dữ liệu trao đổi và hiệu năng của ECDH với DH bằng thư viện chuẩn.

Nội dung lý thuyết cần báo cáo

- Trường hữu hạn, điểm tại vô cực, phép cộng và nhân vô hướng.
- Bài toán logarit rời rạc trên đường cong elliptic.
- Kiểm tra điểm, lựa chọn đường cong và nguy cơ dùng tham số tùy ý.
- Khác biệt giữa mức an toàn, kích thước khóa và chi phí triển khai.

Yêu cầu thực nghiệm

1. Cài đặt phép cộng điểm trên một đường cong nhỏ, liệt kê các điểm và kiểm tra tính đóng.
2. Thực hiện nhân vô hướng bằng cộng lặp và double and add; đo số phép toán.
3. Xây dựng ECDH bằng thư viện chuẩn và dẫn xuất khóa bằng HKDF.
4. Chạy benchmark ECDH và DH với nhiều số phiên, ghi kích thước khóa công khai và thời gian.

5. Tạo kiểm thử điểm không hợp lệ ở mức API an toàn để quan sát cách thư viện từ chối.

Kết quả thực nghiệm cần đạt

- Mô hình học tập đúng với các phép toán đã kiểm chứng.
- Bảng so sánh DH và ECDH trên cùng môi trường.
- Giải thích vì sao kích thước khóa nhỏ hơn không đồng nghĩa thuật toán đơn giản hơn.
- Danh sách quy tắc dùng đường cong và thư viện an toàn.

Sản phẩm và minh chứng bắt buộc

- Bảng các điểm trên đường cong nhỏ
- Kiểm thử các luật đại số
- Mã benchmark và thông tin môi trường
- Log kiểm tra đầu vào
- Biểu đồ thời gian và kích thước

Công nghệ gợi ý Python, Jupyter, cryptography hoặc libsodium, pytest, matplotlib.

Giới hạn an toàn và đạo đức Đường cong tự tạo chỉ dùng trong phần minh họa; phần benchmark phải dùng tham số do thư viện chuẩn cung cấp.

15 Đánh giá nguồn ngẫu nhiên và ảnh hưởng đến khóa cùng nonce

Bám sát mục	3.13, 3.14 và 3.15	**Mức độ**	Khá
Thời lượng	7 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Phân biệt entropy, bộ sinh giả ngẫu nhiên thông thường và bộ sinh dùng cho mật mã.
- Đo một số đặc trưng thống kê mà không tuyên bố chúng chứng minh an toàn mật mã.
- Chứng minh hậu quả của seed dự đoán được hoặc nonce bị lặp trong mô hình giới hạn.

Nội dung lý thuyết cần báo cáo

- Entropy Shannon, min entropy, tính không dự đoán được và tính độc lập.
- Nguồn entropy, DRBG, seed, reseed và giao diện ngẫu nhiên của hệ điều hành.
- Vai trò của ngẫu nhiên đối với khóa, IV, nonce và salt.
- Giới hạn của kiểm thử thống kê và nhu cầu đánh giá thiết kế nguồn sinh.

Yêu cầu thực nghiệm

1. Thu mẫu từ Python random, Python secrets, nguồn hệ điều hành và một bộ sinh tuyến tính tự cài đặt.
2. Chạy kiểm tra phân bố, tương quan, chuỗi lặp và ước lượng entropy đơn giản trên cùng kích thước mẫu.
3. Cố định seed của bộ sinh không mật mã để dự đoán lại chuỗi và khóa mô phỏng.
4. Mô phỏng xác suất va chạm nonce theo số mẫu và kích thước không gian.
5. Đề xuất API an toàn cho ba tác vụ gồm sinh khóa, nonce và token khôi phục.

Kết quả thực nghiệm cần đạt

- Bộ dữ liệu mẫu có mô tả cách thu và kích thước.
- Bảng kết quả thống kê kèm diễn giải đúng giới hạn.
- Minh chứng tái tạo chuỗi khi seed dự đoán được.
- Hướng dẫn lựa chọn nguồn ngẫu nhiên theo mục đích sử dụng.

Sản phẩm và minh chứng bắt buộc

- Mã thu mẫu và kiểm thử
- Tệp mẫu hoặc giá trị băm nếu tệp lớn
- Biểu đồ và bảng thống kê
- Log thử nghiệm seed
- Mô hình va chạm nonce

Công nghệ gợi ý Python, secrets, os.urandom, NumPy, SciPy, Jupyter; có thể dùng bộ kiểm thử NIST ở mức tham khảo nếu nhóm giải thích đúng phạm vi.

Giới hạn an toàn và đạo đức Không lưu hoặc công bố khóa thật; mọi khóa và token trong thí nghiệm phải được tạo riêng cho lab rồi hủy sau khi hoàn thành.

Chương 4 Các cơ chế mật mã hiện đại

Năm đề tài trong phần này chuyển kiến thức của chương thành nhiệm vụ nghiên cứu có sản phẩm và số liệu kiểm chứng. Nhóm cần chọn phạm vi vừa đủ, lập baseline, giữ nguyên điều kiện so sánh và báo cáo cả kết quả không đạt kỳ vọng.

16 So sánh AES GCM và ChaCha20 Poly1305 trong mã hóa có xác thực

Bám sát mục	4.1, 4.2 và 4.9	**Mức độ**	Khá
Thời lượng	6 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Đánh giá đồng thời tính bí mật, toàn vẹn, hiệu năng và yêu cầu quản lý nonce.
- So sánh hai cơ chế AEAD trên nhiều kích thước dữ liệu và môi trường phần cứng.
- Xây dựng bộ kiểm thử sửa đổi bản mã, thẻ và dữ liệu liên kết.

Nội dung lý thuyết cần báo cáo

- Mã hóa có xác thực, dữ liệu liên kết và nguyên tắc xác minh trước khi sử dụng bản rõ.
- Cấu trúc tổng quát của AES GCM và ChaCha20 Poly1305.
- Yêu cầu duy nhất của nonce, giới hạn dữ liệu trên mỗi khóa và hậu quả tái sử dụng.
- Ảnh hưởng của hỗ trợ tăng tốc phần cứng đến kết quả benchmark.

Yêu cầu thực nghiệm

1. Xây dựng chương trình benchmark bằng API mức cao của thư viện mật mã.
2. Đo throughput và độ trễ với dữ liệu từ 1 KB đến 100 MB, lặp đủ số lần và báo cáo độ phân tán.
3. Thực hiện kiểm thử sửa một bit ở bản mã, thẻ và AAD; xác nhận giải mã bị từ chối.
4. Mô phỏng quản lý nonce bằng bộ đếm và bằng ngẫu nhiên, phân tích nguy cơ va chạm.

5. Chạy trên ít nhất hai môi trường nếu có thể, hoặc tắt bật tăng tốc để giải thích khác biệt.

Kết quả thực nghiệm cần đạt

- Bảng benchmark có thông tin máy, thư viện, tham số và số lần lặp.
- Bộ kiểm thử âm chứng minh dữ liệu bị sửa không được chấp nhận.
- Thiết kế định dạng gói dữ liệu gồm phiên bản, nonce, AAD, bản mã và thẻ.
- Khuyến nghị lựa chọn theo môi trường và ràng buộc vận hành.

Sản phẩm và minh chứng bắt buộc

- Mã nguồn benchmark
- Tệp kết quả dạng CSV
- Log kiểm thử âm
- Biểu đồ throughput và độ trễ
- Đặc tả định dạng gói và quy tắc nonce

Công nghệ gợi ý Python cryptography hoặc libsodium, OpenSSL, pytest, pandas và matplotlib.

Giới hạn an toàn và đạo đức Không tự cài đặt lõi AES hoặc ChaCha cho sản phẩm; chỉ dùng API AEAD của thư viện chuẩn.

17 Thiết kế hệ mã lai cho trao đổi tệp có xác thực

Bám sát mục	4.3, 4.4, 4.5, 4.6 và 4.9	**Mức độ**	Nâng cao
Thời lượng	6 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Kết hợp thỏa thuận hoặc đóng gói khóa với dẫn xuất khóa và AEAD thành một quy trình hoàn chỉnh.
- Ràng buộc danh tính, ngữ cảnh và phiên bản giao thức vào quá trình xác thực.
- Kiểm thử lỗi khóa, sửa gói, phát lại và gián đoạn truyền.

Nội dung lý thuyết cần báo cáo

- Hệ mã lai và lý do không dùng mã hóa khóa công khai cho toàn bộ tệp.
- ECDH hoặc RSA OAEP, HKDF, AEAD và phân tách khóa.
- Xác thực khóa công khai, dấu vân tay, chứng chỉ hoặc khóa đã chia sẻ.
- Định dạng thông điệp, versioning, chống phát lại và xử lý lỗi an toàn.

Yêu cầu thực nghiệm

1. Thiết kế đặc tả gói và máy trạng thái gửi nhận trước khi viết mã.
2. Cài đặt hai phương án: X25519 ECDH với HKDF và một phương án RSA OAEP để so sánh.
3. Mã hóa tệp bằng AEAD, gắn metadata cần thiết vào AAD và kiểm tra hash sau giải mã.
4. Xây dựng bộ kiểm thử khóa sai, tệp bị sửa, AAD sai, gói lặp và gói bị cắt.
5. Đo chi phí theo kích thước tệp và số người nhận; phân tích điểm nghẽn.

Kết quả thực nghiệm cần đạt

- Nguyên mẫu dòng lệnh có cấu trúc gói được tài liệu hóa.
- Bộ kiểm thử dương và âm bao phủ các trạng thái lỗi chính.
- Bảng so sánh hai phương án về kích thước, tốc độ và quản lý khóa.
- Mô hình đe dọa cùng danh sách vấn đề chưa giải quyết như thu hồi khóa và xác thực người dùng.

Sản phẩm và minh chứng bắt buộc

- Đặc tả giao thức và sơ đồ tuần tự
- Mã nguồn cùng kiểm thử
- Tệp mẫu trước sau và giá trị băm
- Log lỗi đã chuẩn hóa
- Kết quả benchmark

Công nghệ gợi ý Python cryptography, libsodium hoặc Go crypto, OpenSSL để kiểm tra chéo, pytest, Docker tùy chọn.

Giới hạn an toàn và đạo đức Nguyên mẫu chỉ phục vụ học tập; không tuyên bố tương đương giao thức đã chuẩn hóa hoặc dùng cho dữ liệu sản xuất.

18 Phân biệt hàm băm HMAC và AEAD qua thực nghiệm sửa đổi dữ liệu

Bám sát mục	4.5, 4.6 và 4.9	**Mức độ**	Trung bình
Thời lượng	6 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Chứng minh hàm băm đơn thuần không cung cấp xác thực nguồn gốc khi đối thủ có thể thay cả dữ liệu và giá trị băm.
- So sánh HMAC với AEAD theo mục tiêu bảo vệ và yêu cầu quản lý khóa.
- Xây dựng ma trận lựa chọn cơ chế cho các tình huống thực tế.

Nội dung lý thuyết cần báo cáo

- Tính kháng tiền ảnh, tiền ảnh thứ hai và va chạm.
- HMAC, khóa bí mật, xác thực thông điệp và nguy cơ so sánh không hằng thời gian.
- Khác biệt giữa toàn vẹn không khóa, xác thực có khóa và mã hóa có xác thực.
- SHA 2, SHA 3 và nguyên tắc không tự ghép cơ chế khi chưa có thiết kế chuẩn.

Yêu cầu thực nghiệm

1. Tạo ba phiên bản dịch vụ kiểm tra tệp: hash thuần, HMAC và AEAD.
2. Thực hiện sửa dữ liệu, thay hash, dùng khóa sai, thay thẻ và thay metadata.
3. Đo tỷ lệ phát hiện cho từng cơ chế trên cùng bộ tình huống.
4. So sánh SHA 256 và SHA 3 về tốc độ trên nhiều kích thước dữ liệu mà không suy diễn tốc độ thành mức an toàn.
5. Thiết kế bảng quyết định cho kiểm tra tải xuống, webhook, lưu trữ bí mật và truyền thông điệp.

Kết quả thực nghiệm cần đạt

- Minh chứng trực tiếp về giới hạn của hash thuần.
- Bộ kiểm thử bao phủ lỗi dữ liệu, khóa và metadata.
- Bảng benchmark có diễn giải đúng phạm vi.
- Ma trận lựa chọn cơ chế theo mục tiêu bí mật, toàn vẹn và xác thực.

Sản phẩm và minh chứng bắt buộc

- Mã nguồn ba phiên bản
- Bộ thông điệp kiểm thử
- Log kết quả dương âm
- Biểu đồ tốc độ
- Ma trận quyết định có ví dụ

Công nghệ gợi ý Python hashlib, hmac và cryptography; OpenSSL tùy chọn; pytest và Jupyter.

Giới hạn an toàn và đạo đức Không xây dựng lược đồ mật mã mới; các thí nghiệm chỉ minh họa thuộc tính đã biết.

19 Đánh giá chữ ký số cho phần mềm và tài liệu điện tử

Bám sát mục	4.5, 4.7, 4.8 và 4.9.3	**Mức độ**	Khá
Thời lượng	7 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- So sánh RSA PSS, ECDSA và Ed25519 theo kích thước chữ ký, tốc độ và yêu cầu nonce.
- Thiết kế quy trình ký, xác minh, lưu dấu thời gian và xử lý khóa bị lộ cho artifact.
- Kiểm chứng rằng thay đổi nội dung hoặc metadata được bảo vệ làm xác minh thất bại.

Nội dung lý thuyết cần báo cáo

- Mô hình chữ ký số, tính toàn vẹn, xác thực nguồn gốc và giới hạn của khái niệm chống chối bỏ.
- RSA PSS, ECDSA, EdDSA và cách sinh nonce xác định.
- Dấu vân tay khóa, chứng chỉ, danh sách tin cậy và vòng đời khóa ký.
- Ký artifact, manifest, provenance và vấn đề luân chuyển khóa.

Yêu cầu thực nghiệm

1. Tạo bộ artifact gồm tệp nhị phân nhỏ, tài liệu và manifest metadata.
2. Ký bằng ba thuật toán qua API thư viện chuẩn; đo thời gian, kích thước khóa và chữ ký.
3. Sửa từng thành phần và ghi nhận hành vi xác minh.
4. Mô phỏng luân chuyển khóa với giai đoạn chồng lấn và danh sách khóa tin cậy theo phiên bản.
5. Xây dựng kịch bản khóa bị lộ và quy trình thu hồi, ký lại hoặc cảnh báo người dùng.

Kết quả thực nghiệm cần đạt

- Công cụ ký và xác minh artifact ở mức nguyên mẫu.

- Bảng so sánh định lượng giữa ba cơ chế.
- Manifest có phiên bản và định danh khóa ký.
- Runbook xử lý khóa ký bị lộ cùng bằng chứng kiểm thử.

Sản phẩm và minh chứng bắt buộc

- Artifact gốc và bản bị sửa
- Khóa thử nghiệm và dấu vân tay công khai
- Chữ ký cùng log xác minh
- Tệp benchmark
- Sơ đồ vòng đời khóa ký

Công nghệ gợi ý OpenSSL, GnuPG tùy phạm vi, Python cryptography hoặc libsodium, Sigstore Cosign tùy chọn cho phần mở rộng.

Giới hạn an toàn và đạo đức Khóa thử nghiệm chỉ dùng cho đồ án; không ký nhầm phần mềm thật bằng danh tính hoặc chứng thư của tổ chức.

20 Xây dựng hạ tầng khóa công khai thu nhỏ và kiểm thử TLS 1.3

Bám sát mục	4.4, 4.8 và 4.9.1	**Mức độ**	Nâng cao
Thời lượng	6 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Triển khai chuỗi tin cậy gồm CA gốc, CA trung gian và chứng thư dịch vụ trong môi trường lab.
- Kiểm chứng xác thực tên máy, thời hạn, mục đích sử dụng khóa và chuỗi chứng thư.
- Đo và mô tả quy trình cấp, gia hạn, luân chuyển và xử lý sự cố khóa.

Nội dung lý thuyết cần báo cáo

- Chứng thư X.509, chuỗi tin cậy, CA gốc, CA trung gian và trust store.
- TLS 1.3, thỏa thuận khóa, xác thực máy chủ và an toàn chuyển tiếp.
- Vòng đời khóa, CSR, key usage, SAN, hết hạn, thu hồi và ghim khóa trong phạm vi phù hợp.
- Mô hình đe dọa đối với khóa CA và nguyên tắc tách biệt quyền ký.

Yêu cầu thực nghiệm

1. Dựng CA gốc ngoại tuyến mô phỏng và CA trung gian dùng để cấp chứng thư dịch vụ.
2. Cấu hình hai dịch vụ HTTPS và một client tin cậy vào CA lab.
3. Kiểm thử đúng tên, sai tên, hết hạn, thiếu intermediate, CA không tin cậy và khóa bị thay.
4. Bắt tay TLS bằng công cụ phân tích để nhận diện phiên bản, bộ mật mã và chứng thư mà không giải mã trái phép.
5. Thực hiện gia hạn hoặc luân chuyển chứng thư và đo thời gian gián đoạn.

Kết quả thực nghiệm cần đạt

- PKI thu nhỏ hoạt động với chính sách cấp chứng thư rõ ràng.
- Bảng kết quả tối thiểu sáu tình huống xác minh chứng thư.
- Runbook cấp, gia hạn, luân chuyển và thu hồi.

- Phân tích các giới hạn của lab, đặc biệt là kiểm tra thu hồi và bảo vệ khóa CA.

Sản phẩm và minh chứng bắt buộc

- Cấu trúc thư mục PKI và file cấu hình đã che khóa
- Chuỗi chứng thư công khai
- Log openssl s_client hoặc tương đương
- Tệp pcap bắt tay TLS
- Video luân chuyển chứng thư

Công nghệ gợi ý OpenSSL hoặc step ca, Nginx hoặc Caddy, Docker, Wireshark, curl.

Giới hạn an toàn và đạo đức CA lab không được cài vào hệ thống dùng hàng ngày hoặc dùng để giả mạo tên miền thật; khóa riêng không đưa vào báo cáo công khai.

Chương 5 An toàn thông tin trong kỷ nguyên trí tuệ nhân tạo và điện toán lượng tử

Năm đề tài trong phần này chuyển kiến thức của chương thành nhiệm vụ nghiên cứu có sản phẩm và số liệu kiểm chứng. Nhóm cần chọn phạm vi vừa đủ, lập baseline, giữ nguyên điều kiện so sánh và báo cáo cả kết quả không đạt kỳ vọng.

21 Đánh giá phòng vệ trước prompt injection trong hệ thống RAG

Bám sát mục	5.1 đến 5.3	**Mức độ**	Nâng cao
Thời lượng	8 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Xây dựng bộ kiểm thử prompt injection trực tiếp và gián tiếp trên dữ liệu giả lập.
- Đánh giá phòng vệ nhiều lớp gồm kiểm soát truy xuất, phân tách chỉ dẫn, lọc đầu ra và giới hạn công cụ.
- Đo đồng thời tỷ lệ tấn công thành công và suy giảm chất lượng trả lời hợp lệ.

Nội dung lý thuyết cần báo cáo

- Kiến trúc RAG, tài sản, ranh giới tin cậy và dữ liệu không tin cậy.
- Prompt injection, rò rỉ chỉ dẫn, truy xuất vượt quyền và sử dụng công cụ sai mục đích.
- Nguyên tắc tách dữ liệu khỏi chỉ dẫn, allowlist công cụ, xác thực lại ở lớp nghiệp vụ và phê duyệt con người.
- Thiết kế bộ đánh giá, false positive, false negative và khả năng tái tạo.

Yêu cầu thực nghiệm

1. Dựng RAG cục bộ với tài liệu giả lập, trong đó một số tài liệu chứa chỉ dẫn độc hại được gắn nhãn.
2. Tạo tối thiểu 40 ca kiểm thử gồm truy vấn bình thường, vượt quyền, lộ chỉ dẫn và thao túng công cụ.
3. Đo baseline trước kiểm soát, sau đó áp dụng từng lớp phòng vệ để thực hiện ablation study.
4. Ghi nhận tỷ lệ tấn công thành công, tỷ lệ trả lời đúng, tỷ lệ từ chối nhầm và độ trễ.

5. Phân tích các trường hợp còn thất bại và đề xuất giới hạn chức năng thay vì chỉ thêm bộ lọc.

Kết quả thực nghiệm cần đạt

- Bộ benchmark có dữ liệu, nhãn và tiêu chí chấm rõ ràng.
- Nguyên mẫu RAG với ít nhất ba lớp kiểm soát.
- Bảng ablation cho biết đóng góp của từng kiểm soát.
- Mô hình đe dọa và khuyến nghị triển khai theo mức rủi ro.

Sản phẩm và minh chứng bắt buộc

- Bộ tài liệu và prompt giả lập
- Mã nguồn cấu hình RAG
- Log từng ca kiểm thử đã làm sạch
- Bảng kết quả và biểu đồ
- Video một ca tấn công trước sau kiểm soát

Công nghệ gợi ý Ollama hoặc mô hình cục bộ, LangChain hoặc LlamaIndex, FAISS hoặc Chroma, Python, garak tùy chọn, Docker.

Giới hạn an toàn và đạo đức Không thử prompt injection trên dịch vụ của bên thứ ba nếu không có quyền; dữ liệu và công cụ đều phải giả lập.

22 Tấn công suy luận thành viên và quyền riêng tư vi sai trên mô hình học máy

Bám sát mục	5.2.1, 5.3.1 và 5.4	**Mức độ**	Nâng cao
Thời lượng	6 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Đo nguy cơ suy luận một bản ghi có thuộc tập huấn luyện hay không.
- Áp dụng huấn luyện có quyền riêng tư vi sai và quan sát đánh đổi giữa riêng tư với độ chính xác.
- Báo cáo tham số riêng tư và điều kiện thí nghiệm một cách có thể kiểm tra.

Nội dung lý thuyết cần báo cáo

- Membership inference, overfitting và tín hiệu từ xác suất dự đoán.
- Khái niệm epsilon, delta, độ nhạy, clipping, nhiễu và privacy accountant.
- DP SGD, giới hạn của việc diễn giải epsilon và sự khác biệt giữa riêng tư với bảo mật truy cập.
- Các chỉ số utility, attack AUC, accuracy, F1 và khoảng biến thiên qua nhiều seed.

Yêu cầu thực nghiệm

1. Chọn bộ dữ liệu công khai nhỏ và mô hình phân loại có thể huấn luyện trong thời gian giới hạn.
2. Huấn luyện baseline không DP và thực hiện tấn công suy luận thành viên ở mức học thuật.
3. Huấn luyện nhiều cấu hình DP với clipping và noise multiplier khác nhau.
4. Lặp thí nghiệm với ít nhất ba seed; ghi epsilon, utility và attack AUC.

5. Phân tích cấu hình nào giảm rủi ro tấn công nhưng vẫn giữ utility chấp nhận được.

Kết quả thực nghiệm cần đạt

- Pipeline huấn luyện và đánh giá tái tạo được.
- Đường cong privacy utility và attack utility.
- Bảng tham số đầy đủ gồm batch size, số epoch, clipping, noise và accountant.
- Kết luận giới hạn trong phạm vi bộ dữ liệu và mô hình đã thử.

Sản phẩm và minh chứng bắt buộc

- Notebook hoặc mã nguồn
- Tệp cấu hình và seed
- Log epsilon theo epoch
- Kết quả tấn công và biểu đồ
- Model card ngắn mô tả mục đích và giới hạn

Công nghệ gợi ý PyTorch, Opacus, scikit learn, ART hoặc cài đặt tấn công đơn giản, Jupyter, MLflow tùy chọn.

Giới hạn an toàn và đạo đức Chỉ dùng dữ liệu công khai hoặc dữ liệu tổng hợp; không thử suy luận thành viên trên mô hình hoặc tập dữ liệu thật của tổ chức.

23 Phát hiện đầu độc dữ liệu và kiểm soát nguồn gốc tập huấn luyện

Bám sát mục	5.2.1, 5.2.3 và 5.3.1 đến 5.3.2	**Mức độ**	Nâng cao
Thời lượng	8 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Mô phỏng tác động của dữ liệu sai nhãn hoặc mẫu kích hoạt lành tính đối với mô hình nhỏ.
- Đánh giá các biện pháp kiểm tra nguồn gốc, thống kê dữ liệu và phê duyệt phiên bản.
- Xây dựng chuỗi bằng chứng cho biết dữ liệu nào đã tạo ra phiên bản mô hình nào.

Nội dung lý thuyết cần báo cáo

- Data poisoning, backdoor ở mức khái niệm, model drift và integrity của pipeline.
- Nguồn gốc dữ liệu, checksum, versioning, lineage và kiểm soát thay đổi.
- Phát hiện ngoại lệ, kiểm tra nhãn, lấy mẫu thủ công và giới hạn của phương pháp thống kê.
- Ký artifact, phân tách quyền nhập dữ liệu và phê duyệt trước huấn luyện.

Yêu cầu thực nghiệm

1. Tạo bộ dữ liệu hình ảnh hoặc bảng nhỏ có phiên bản sạch và các mức nhiễu nhãn khác nhau.
2. Có thể thêm trigger vô hại vào một lớp trên dữ liệu tổng hợp để đo hành vi mục tiêu trong môi trường kín.
3. Huấn luyện mô hình cho từng phiên bản và đo accuracy, F1, attack success rate nếu dùng trigger.
4. Áp dụng kiểm tra hash, thống kê phân bố, phát hiện ngoại lệ và quy trình review mẫu.

5. So sánh khả năng phát hiện, chi phí và số mẫu sạch bị loại nhầm.

Kết quả thực nghiệm cần đạt

- Kho dữ liệu có version và manifest nguồn gốc.
- Bảng tác động của từng mức đầu độc lên mô hình.
- Đánh giá định lượng ít nhất hai kiểm soát phát hiện.
- Quy trình phê duyệt dữ liệu và liên kết dataset model metric.

Sản phẩm và minh chứng bắt buộc

- Manifest và checksum của từng phiên bản
- Mã tạo nhiễu hoặc trigger lành tính
- Log huấn luyện
- Ma trận nhầm lẫn và kết quả phát hiện
- Sơ đồ lineage

Công nghệ gợi ý DVC hoặc Git LFS, Python, scikit learn hoặc PyTorch, pandas, MLflow tùy chọn.

Giới hạn an toàn và đạo đức Chỉ nghiên cứu trên mô hình nhỏ và dữ liệu công khai hoặc tổng hợp; không phát tán bộ dữ liệu đầu độc hoặc hướng dẫn nhắm vào hệ thống thật.

24 Học liên kết kết hợp quyền riêng tư vi sai trong dữ liệu không đồng nhất

Bám sát mục	5.3, 5.4 và 5.4.1	**Mức độ**	Nâng cao
Thời lượng	6 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Mô phỏng nhiều bên huấn luyện chung mà không chuyển dữ liệu thô về máy chủ.
- Đánh giá ảnh hưởng của dữ liệu không đồng nhất, nhiễu DP và tỷ lệ tham gia client.
- Phân biệt việc giữ dữ liệu tại nguồn với bảo đảm chống rò rỉ từ cập nhật mô hình.

Nội dung lý thuyết cần báo cáo

- Federated learning, FedAvg, client selection và dữ liệu non IID.
- Rò rỉ từ gradient hoặc cập nhật, đầu độc client và điểm tin cậy của máy chủ tổng hợp.
- DP cục bộ hoặc trung tâm, clipping và privacy accounting.
- Các chỉ số utility, fairness giữa client, overhead truyền thông và ổn định huấn luyện.

Yêu cầu thực nghiệm

1. Chia bộ dữ liệu công khai thành ít nhất năm client với hai mức non IID.
2. Huấn luyện tập trung làm mốc, sau đó chạy federated baseline.
3. Bổ sung clipping và nhiễu ở ít nhất ba cấu hình; thay đổi tỷ lệ client tham gia.
4. Đo accuracy tổng thể, accuracy từng client, số vòng hội tụ, dữ liệu truyền và epsilon nếu có accountant.
5. Phân tích trường hợp một client có dữ liệu lệch hoặc cập nhật bất thường ở mức mô phỏng an toàn.

Kết quả thực nghiệm cần đạt

- Môi trường mô phỏng liên kết chạy lặp lại được.
- Bảng so sánh tập trung, liên kết và liên kết có DP.
- Phân tích utility privacy fairness overhead dựa trên số liệu.
- Khuyến nghị kiến trúc và giới hạn của mô phỏng so với triển khai phân tán thật.

Sản phẩm và minh chứng bắt buộc

- Tệp chia dữ liệu và seed
- Cấu hình từng client
- Log vòng huấn luyện
- Biểu đồ chỉ số tổng thể và từng client
- Bảng ước lượng lưu lượng truyền

Công nghệ gợi ý Flower hoặc TensorFlow Federated, PyTorch, Opacus hoặc TensorFlow Privacy, Docker tùy chọn.

Giới hạn an toàn và đạo đức Không dùng dữ liệu bệnh án, tài chính hoặc dữ liệu cá nhân thật; mọi client là tiến trình mô phỏng hoặc máy ảo do nhóm quản lý.

25 Kiểm kê mật mã và thử nghiệm lộ trình chuyển đổi hậu lượng tử

Bám sát mục	5.5 đến 5.7	**Mức độ**	Nâng cao
Thời lượng	8 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Xây dựng crypto inventory cho một hệ thống giả lập và ưu tiên thành phần cần chuyển đổi.
- Benchmark ML KEM, ML DSA và SLH DSA bằng thư viện thử nghiệm.
- Đề xuất lộ trình crypto agility có kiểm soát phiên bản, tương thích và hoàn nguyên.

Nội dung lý thuyết cần báo cáo

- Tác động khác nhau của Shor và Grover đối với mật mã khóa công khai, đối xứng và hàm băm.
- Mục đích của ML KEM, ML DSA, SLH DSA và các tham số chuẩn.
- Harvest now decrypt later, thời hạn bí mật của dữ liệu và thiết bị khó nâng cấp.
- Crypto agility, hybrid deployment, downgrade và quản lý phụ thuộc thư viện.

Yêu cầu thực nghiệm

1. Tạo hệ thống giả lập gồm TLS, VPN, chứng thư, chữ ký phần mềm, cơ sở dữ liệu và thiết bị IoT.
2. Lập inventory thuật toán, khóa, chứng thư, thư viện, chủ sở hữu và thời hạn bí mật.
3. Dùng liboqs hoặc oqs provider để benchmark key generation, encapsulation, signing và verification.
4. So sánh kích thước khóa, bản mã, chữ ký, thời gian và bộ nhớ với cơ chế cổ điển tương ứng.

5. Thiết kế thử nghiệm tương thích hoặc hybrid ở phạm vi nhỏ, có kế hoạch rollback và kiểm tra downgrade.

Kết quả thực nghiệm cần đạt

- Crypto inventory có mức ưu tiên và phụ thuộc.
- Bảng benchmark đầy đủ cho các chuẩn hậu lượng tử đã chọn.
- Lộ trình theo giai đoạn gồm thử nghiệm, triển khai song song, chuyển đổi và loại bỏ cơ chế cũ.
- Danh sách rủi ro vận hành và tiêu chí dừng hoặc hoàn nguyên.

Sản phẩm và minh chứng bắt buộc

- Biểu mẫu inventory
- Script benchmark và tệp kết quả
- Thông tin phiên bản thư viện
- Sơ đồ phụ thuộc mật mã
- Kế hoạch migration và rollback

Công nghệ gợi ý Open Quantum Safe liboqs và oqs provider, OpenSSL, Python hoặc C, Docker, công cụ tạo biểu đồ.

Giới hạn an toàn và đạo đức Chỉ dùng thư viện thử nghiệm trong lab; không thay thuật toán trên dịch vụ thật và không tuyên bố sẵn sàng sản xuất nếu chưa được đánh giá độc lập.

Chương 6 An toàn thông tin trong kiến trúc hệ thống hiện đại

Năm đề tài trong phần này chuyển kiến thức của chương thành nhiệm vụ nghiên cứu có sản phẩm và số liệu kiểm chứng. Nhóm cần chọn phạm vi vừa đủ, lập baseline, giữ nguyên điều kiện so sánh và báo cáo cả kết quả không đạt kỳ vọng.

26 Mô hình hóa mối đe dọa STRIDE cho ngân hàng số trên đám mây

Bám sát mục	6.1, 6.2, 6.4 và 6.8.1	**Mức độ**	Khá
Thời lượng	7 đến 8 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Xây dựng mô hình hệ thống có tài sản, danh tính, luồng dữ liệu và ranh giới tin cậy.
- Áp dụng STRIDE để nhận diện đe dọa và truy vết kiểm soát đến từng luồng.
- Đánh giá phần trách nhiệm của khách hàng và nhà cung cấp trong kiến trúc đám mây giả lập.

Nội dung lý thuyết cần báo cáo

- Nguyên tắc quyền tối thiểu, phân tách trách nhiệm, mặc định an toàn và lỗi theo trạng thái an toàn.
- DFD, ranh giới tin cậy, STRIDE và cây tấn công.
- Mô hình trách nhiệm chia sẻ, IAM, phân đoạn, mã hóa, log và phục hồi.
- Kiểm soát nghiệp vụ giao dịch gồm xác thực lại, giới hạn, idempotency và audit trail.

Yêu cầu thực nghiệm

1. Thiết kế kiến trúc ngân hàng số giả lập gồm ứng dụng, gateway, dịch vụ tài khoản, thanh toán, cơ sở dữ liệu và đối tác.
2. Vẽ DFD cấp bối cảnh và cấp thành phần, đánh số mọi luồng và kho dữ liệu.
3. Thực hiện STRIDE cho từng thành phần và chọn tối thiểu 20 đe dọa có căn cứ.
4. Ánh xạ kiểm soát và xây dựng năm abuse case để kiểm tra thiết kế.
5. Dựng nguyên mẫu nhỏ hoặc mô phỏng chính sách cho hai luồng quan trọng và thu log cho phép hoặc từ chối.

Kết quả thực nghiệm cần đạt

- Bộ DFD nhất quán với danh mục tài sản và danh tính.
- Threat register có mức ưu tiên, kiểm soát, chủ sở hữu và trạng thái.
- Ma trận trách nhiệm chia sẻ và kiểm soát còn thiếu.
- Bằng chứng kiểm thử hai luồng nghiệp vụ quan trọng.

Sản phẩm và minh chứng bắt buộc

- DFD và sơ đồ triển khai
- Bảng STRIDE và abuse case
- Ma trận tài sản luồng kiểm soát
- Mã hoặc policy nguyên mẫu
- Log kiểm thử và biên bản review chéo

Công nghệ gợi ý OWASP Threat Dragon hoặc Microsoft Threat Modeling Tool, diagrams.net, Docker Compose, Keycloak, OPA tùy chọn.

Giới hạn an toàn và đạo đức Kiến trúc và dữ liệu phải giả lập; không sử dụng cấu hình, khóa hoặc sơ đồ nội bộ của ngân hàng thật.

27 Kiểm thử phân quyền đối tượng và giới hạn lạm dụng API

Bám sát mục	6.2, 6.3 và 6.8	**Mức độ**	Khá
Thời lượng	7 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Nhận diện lỗi phân quyền ở cấp đối tượng và cấp chức năng trong API.
- Thiết kế kiểm soát token, audience, phạm vi quyền, rate limit và kiểm tra nghiệp vụ.
- Xây dựng bộ kiểm thử hồi quy để ngăn lỗi tái xuất hiện.

Nội dung lý thuyết cần báo cáo

- Xác thực, quản lý phiên, phân quyền và kiểm tra quyền trên từng đối tượng.
- BOLA, broken function level authorization, mass assignment và resource consumption.
- JWT, issuer, audience, thời hạn, scope và giới hạn của chữ ký token.
- Rate limiting, idempotency, validation schema và logging có ngữ cảnh.

Yêu cầu thực nghiệm

1. Dùng OWASP crAPI hoặc ứng dụng API tự viết trong mạng cô lập.

2. Lập ma trận người dùng vai trò hành động tài nguyên trước khi kiểm thử.
3. Tạo ca kiểm thử truy cập đối tượng khác, gọi chức năng quản trị, sửa trường không cho phép và gửi lặp giao dịch.
4. Bổ sung middleware hoặc policy kiểm soát rồi chạy lại toàn bộ bộ test.
5. Đo tỷ lệ ca bị chặn đúng, lỗi hồi quy và ảnh hưởng đến độ trễ.

Kết quả thực nghiệm cần đạt

- Ma trận phân quyền và đặc tả policy có thể kiểm tra.
- Bộ test tự động cho các lỗi API trọng yếu.
- Bảng before after chứng minh kiểm soát hiệu quả.
- Hướng dẫn ghi log đủ điều tra nhưng không lộ token hoặc dữ liệu nhạy cảm.

Sản phẩm và minh chứng bắt buộc

- Mã nguồn hoặc cấu hình lab
- Bộ request response đã khử bí mật
- Ma trận quyền
- Kết quả kiểm thử tự động
- Log từ chối có correlation ID

Công nghệ gợi ý OWASP crAPI, Postman hoặc Bruno, pytest, Newman, Keycloak, OPA, OWASP ZAP API scan, Docker.

Giới hạn an toàn và đạo đức Chỉ kiểm thử API trong lab; không dùng token, tài khoản hoặc endpoint của hệ thống thật.

28 Kiến trúc Zero Trust cho ứng dụng vi dịch vụ trong Kubernetes

Bám sát mục	6.1, 6.4, 6.5 và 6.6	**Mức độ**	Nâng cao
Thời lượng	8 đến 9 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Áp dụng danh tính workload, quyền tối thiểu và phân đoạn vi mô cho vi dịch vụ.
- Chứng minh đường truy cập được phép và bị từ chối bằng policy cùng log.
- Đánh giá ảnh hưởng của Zero Trust đến vận hành và khả năng khắc phục sự cố.

Nội dung lý thuyết cần báo cáo

- Zero Trust, policy decision point, policy enforcement point và đánh giá theo ngữ cảnh.
- Danh tính người dùng và workload, token ngắn hạn, mTLS và audience.
- Kubernetes RBAC, service account, network policy và admission policy.
- Khả năng quan sát, default deny, break glass và kiểm soát thay đổi policy.

Yêu cầu thực nghiệm

1. Dựng cụm kind hoặc minikube với ba vi dịch vụ và cơ sở dữ liệu giả lập.
2. Mô tả ma trận giao tiếp cần thiết rồi áp dụng network policy mặc định từ chối.
3. Cấu hình RBAC và service account riêng; kiểm thử các hành động vượt quyền.
4. Bổ sung OPA Gatekeeper hoặc Kyverno để ngăn cấu hình không phù hợp.

5. Thu log cho các đường allowed denied, đo tác động độ trễ và thử quy trình break glass có giám sát.

Kết quả thực nghiệm cần đạt

- Kiến trúc có danh tính và ranh giới rõ ràng.
- Policy as code cùng bộ kiểm thử dương âm.
- Bảng quyền trước sau và minh chứng giảm đường truy cập không cần thiết.
- Runbook xử lý lỗi policy và thu hồi quyền khẩn cấp.

Sản phẩm và minh chứng bắt buộc

- Manifest Kubernetes
- Ma trận giao tiếp và quyền
- Kết quả policy test
- Log network và admission
- Sơ đồ quyết định truy cập

Công nghệ gợi ý Kubernetes kind hoặc minikube, Calico hoặc Cilium, Keycloak tùy chọn, OPA Gatekeeper hoặc Kyverno, Prometheus và Grafana tùy chọn.

Giới hạn an toàn và đạo đức Chỉ triển khai trên cụm lab; không dùng kubeconfig hoặc thông tin xác thực của cụm thật.

29 Quản lý bí mật và khóa cho vi dịch vụ bằng thông tin xác thực ngắn hạn

Bám sát mục	6.5, 6.6 và 6.8	**Mức độ**	Nâng cao
Thời lượng	8 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Loại bỏ bí mật tĩnh khỏi mã nguồn và ảnh container.
- Cấp bí mật hoặc chứng thư ngắn hạn dựa trên danh tính workload.
- Kiểm thử luân chuyển, thu hồi, mất dịch vụ quản lý bí mật và khả năng phục hồi.

Nội dung lý thuyết cần báo cáo

- Vòng đời bí mật và khóa, envelope encryption, KEK, DEK và KMS HSM.
- Danh tính workload, token ngắn hạn, dynamic secrets và mTLS.
- Secret zero, bootstrap trust, audit log và phân tách quyền quản trị.
- Luân chuyển, thu hồi, cache có giới hạn và thiết kế lỗi theo trạng thái an toàn.

Yêu cầu thực nghiệm

1. Dựng hai dịch vụ và cơ sở dữ liệu trong Docker hoặc Kubernetes.
2. Chứng minh baseline có bí mật tĩnh rồi thay bằng Vault hoặc cơ chế tương đương để cấp thông tin xác thực động.
3. Thiết lập TTL, lease, policy theo workload và audit log.
4. Kiểm thử luân chuyển khi dịch vụ đang chạy, thu hồi khẩn cấp, token hết hạn và Vault tạm thời không sẵn sàng.
5. Đo thời gian phục hồi, số yêu cầu lỗi và khoảng thời gian bí mật cũ còn hiệu lực.

Kết quả thực nghiệm cần đạt

- Không còn bí mật thật trong repository và image sau khi quét.
- Policy cấp quyền theo workload và thời hạn rõ ràng.
- Bảng kết quả các tình huống rotation revoke expiry outage.
- Runbook sự cố bí mật bị lộ và hướng dẫn khởi tạo môi trường mới.

Sản phẩm và minh chứng bắt buộc

- Kết quả quét repository và image
- Policy Vault đã che thông tin nhạy cảm
- Audit log
- Biểu đồ lỗi khi luân chuyển
- Video thu hồi và cấp lại quyền

Công nghệ gợi ý HashiCorp Vault hoặc OpenBao, Docker hoặc Kubernetes, Gitleaks, Trivy, cert manager tùy chọn, OpenTelemetry.

Giới hạn an toàn và đạo đức Mọi token và khóa đều thuộc lab; báo cáo chỉ hiển thị giá trị đã che hoặc dấu vân tay.

30 Kiến trúc an toàn cho tác tử AI tạo yêu cầu thanh toán và sổ kiểm toán chống sửa đổi

Bám sát mục	6.1, 6.2, 6.3, 6.7 và 6.8.2	**Mức độ**	Nâng cao
Thời lượng	8 đến 9 tuần	**Quy mô**	Nhóm 3 sinh viên

Mục tiêu của đề tài

- Thiết kế tác tử AI không được tự quyết định thanh toán ngoài chính sách đã phê duyệt.
- Kết hợp schema công cụ, giới hạn giao dịch, phê duyệt con người, idempotency và khả năng dừng khẩn cấp.
- Đánh giá sổ kiểm toán băm nối tiếp hoặc sổ cái cấp phép trong việc phát hiện sửa đổi.

Nội dung lý thuyết cần báo cáo

- Danh tính và quyền của tác tử, prompt injection, confused deputy và quyền công cụ quá rộng.
- Kiểm soát nghiệp vụ tại API, phê duyệt bốn mắt, giới hạn số tiền và xác thực lại.
- Audit trail, hash chain, chữ ký số, timestamp và giới hạn của blockchain.
- Khả năng quan sát, correlation ID, kill switch, incident response và phục hồi giao dịch.

Yêu cầu thực nghiệm

1. Dựng tác tử hoặc trình mô phỏng tạo đề nghị thanh toán từ dữ liệu giả lập; tác tử chỉ gọi API sandbox.
2. Thiết kế schema chặt, allowlist người nhận, hạn mức, idempotency key và bước phê duyệt con người.
3. Tạo tối thiểu 25 ca gồm lệnh hợp lệ, prompt độc hại, người nhận lạ, số tiền vượt hạn mức và gửi lặp.

4. Ghi sự kiện vào hash chained log hoặc Hyperledger Fabric ở mức tùy chọn; thử sửa, xóa và chèn bản ghi để kiểm tra khả năng phát hiện.
5. Kích hoạt kill switch, thu hồi token và xác minh các yêu cầu mới bị chặn nhưng bằng chứng cũ còn kiểm tra được.

Kết quả thực nghiệm cần đạt

- Kiến trúc tác tử có ranh giới quyền và điểm phê duyệt rõ ràng.
- Bộ kiểm thử nghiệp vụ và an toàn với kết quả mong đợi.
- Sổ kiểm toán phát hiện được các thay đổi trái phép trong phạm vi mô hình.
- Runbook dừng tác tử, thu hồi quyền, điều tra và khôi phục hoạt động.

Sản phẩm và minh chứng bắt buộc

- Sơ đồ kiến trúc và luồng phê duyệt
- Đặc tả API và schema
- Bộ prompt và giao dịch giả lập
- Log băm nối tiếp hoặc ledger cùng phép thử sửa đổi
- Video kill switch và thu hồi token

Công nghệ gợi ý Python FastAPI, PostgreSQL, Keycloak, OPA, mô hình cục bộ hoặc trình mô phỏng quy tắc, thư viện chữ ký băm; Hyperledger Fabric là phần mở rộng không bắt buộc.

Giới hạn an toàn và đạo đức Không kết nối cổng thanh toán thật, không dùng số tài khoản thật và không cấp cho tác tử quyền thực hiện giao dịch bên ngoài sandbox.